VELLORE INSTITUTE OF TECHNOLOGY, VELLORE
BCSE318L – Data Privacy | Fall Semester 2026–27
Final Review — Project Report

Title of the project

Privacy-Preserving Enterprise Copilots: A DPDP-Aligned Risk Assessment and Mitigation Framework for Retrieval-Augmented LLM Assistants in Indian Organisations

Short title: Copilot Privacy Guard. Topic No. 35 — Privacy Implications of LLM-based Enterprise Assistants. Source code: github.com/Adi07289/copilot-privacy-guard

Name and registration number of the students

Name	Registration No.	Programme
Aditya Sharma	23BCE0936	B.Tech CSE (Core)
Aarav Raina	23BCE0992	B.Tech CSE

Faculty in-charge: Dr. Geetha Mary A

Abstract

Retrieval-augmented enterprise assistants such as Microsoft 365 Copilot answer natural-language questions over email, HR records, tickets and code, which turns every over-shared document into something a single query can surface. We designed, implemented and evaluated Copilot Privacy Guard, a middleware that sits between the assistant and its data and applies four controls: India-first PII redaction (applied to the prompt, to the vector index and to retrieved chunks), a purpose-based access filter that encodes the DPDP Act's purpose limitation as a runtime rule, prompt-injection screening that combines a heuristic with an LLM-as-judge, and a SHA-256 hash-chained audit log. On a synthetic Indian-enterprise corpus (80 documents, 369 labelled PII spans, 4 poisoned documents) and 36 queries across five personas, we compared the guard against simplified analogues of six defence families from the literature, run on the identical corpus, retriever and LLM. The guard reduced PII sent to the LLM provider from 100% to 0%, over-sharing from 50.9% to 0%, raw PII stored in the index from 100% to 0%, and the share of poisoned chunks reaching the model from 100% to 0%. Its PII detector reached an F1 of 89.5% on a held-out set against 54.3% for Microsoft Presidio as shipped, and the LLM judge detected 100% of 24 injection payloads (including paraphrased and Hindi ones) with no false positives on hard negatives, against 33% for the heuristic. These gains cost answer utility (34.9% ROUGE-L retention against the undefended answers) and a median of +97 ms per query (an uncached judge call takes about 553 ms), which we report as the central trade-off. All controls are mapped clause by clause to the DPDP Act 2023, DPDP Rules 2025, GDPR and the EU AI Act, with a DPIA risk register and a 13-item assurance checklist that runs against the system (12 pass).

Introduction

Retrieval-augmented generation (RAG) couples a language model with a retriever over an external corpus so that answers are grounded in an organisation's own documents [1]. Enterprise copilots apply this design to

email, chat, documents, tickets, HR systems and code repositories, and they inherit the permissions of the user who asks. That choice inverts a long-standing security assumption: instead of information being compartmentalised by role, one conversational interface can surface any document the user's identity is technically — though rarely intentionally — allowed to open. Industry audits of Copilot roll-outs report that roughly 15–16% of business-critical files are already over-shared before an assistant is introduced; the assistant does not create these exposures, it makes them discoverable in seconds.

The research literature shows that the threat is concrete. Large models memorise and regurgitate training data [2], including personally identifiable information [3]. RAG adds a second, more direct surface: the retrieval database itself leaks under targeted prompts [6], instruction-following prompts can extract retrieved content at scale [7], and optimiser-crafted attacks report near-total PII extraction from undefended systems [10]. Retrieved content can also carry instructions: indirect prompt injection lets an attacker who can write one document steer the assistant for everyone who retrieves it [13]. Defences exist for parts of the problem — for example decoding-time noise that limits how much retrieved text the model reproduces [11] — but they operate on tokens and logits and do not know who is asking or why.

Privacy, however, is about appropriate flows, not only secrecy: the same fact can be fine to share with HR and wrong to share with an intern, which is the contextual-integrity view that recent LLM benchmarks show models fail to respect [28]. Database research addressed this two decades ago with purpose-based access control, where access is granted only when the purpose of a request is compatible with the purpose the data was collected for [29]. India's Digital Personal Data Protection Act, 2023 makes that principle law — personal data may be processed only for a lawful purpose and consent covers only the data necessary for it — and the DPDP Rules notified in November 2025 add concrete security-safeguard, logging and breach-intimation duties that become enforceable in 2027. In parallel the EU AI Act's obligations have started to apply. Organisations are therefore in exactly the window in which a deployable, measurable defence has practical value.

This work contributes: (1) a four-control privacy-guard middleware plus a privacy-preserving (redacted) vector index, implemented as one configurable pipeline; (2) a same-corpus comparative study against simplified analogues of six defence families from the literature, with a leave-one-out ablation; (3) an India-first PII detector evaluated head-to-head against Microsoft Presidio on a held-out set; (4) an injection-detection benchmark comparing a heuristic, an LLM judge and Meta's Prompt Guard 2; and (5) compliance as code — a verified clause map, a DPIA register and an executable assurance checklist whose evidence is drawn from the measured results.

Literature review

Memorisation and membership inference. Training-data extraction [2] and PII-specific leakage analyses [3] established that models leak what they were trained on; membership-inference work now spans every stage of the LLM pipeline including RAG [4] and semantic attacks outperform token-level ones [5]. These works concern model parameters rather than the retrieval context an enterprise copilot assembles at query time.

RAG leakage and its defences. RAG systems leak their datastores [6, 7]; graph-structured RAG adds entity/relationship leakage [8]; active-learning [9] and optimiser-based [10] attacks raise extraction rates further, all against systems with no screening layer. On the defence side, Privacy-Aware Decoding perturbs logits so retrieved content is reproduced less faithfully [11], and a two-stage retriever with an LLM-judged

leakage metric avoids the context loss of coarse redaction [12]. Neither models who is asking: the private context still reaches the model, and organisational permissions are absent.

Prompt injection. Indirect injection through retrieved content was introduced by Greshake et al. [13] and formalised and benchmarked by Liu et al. [14]; surveys catalogue structural defences [15, 21] and OWASP ranks prompt injection first among LLM risks [16]. StruQ separates instructions from data but needs fine-tuning [17]; Spotlighting marks untrusted input with prompt-only delimiting and encoding [18]; LLM-based guards such as Llama Guard classify unsafe content [19], building on evidence that strong LLMs are reliable judges [20]. The surveys themselves note that these defences are rarely evaluated together as one deployable pipeline.

Embeddings, PII detection, access control and auditing. Embeddings leak their inputs [24], and Vec2Text inverts them back to text [22, 23]; noise-based defences trade off utility [25]. PII detectors generalise poorly across sources [26], and hybrid rule-plus-NER pipelines perform well within one domain [27]. Purpose-based [29] and role-based [30] access control, LINDDUN threat modelling [31] and hash-chained audit logs [32] are mature ideas that have not been combined inside an LLM retrieval pipeline. Table 1 summarises the reviewed works; the articles below are closely related to this topic but differ in implementation.

Table 1. Comparative literature matrix.

Reference No.	Year of publication	Authors and Title	Contributions	Limitations
1	2020	P. Lewis, E. Perez, A. Piktus et al.. Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks	1. Combines a parametric generator with a dense retriever over an external corpus 2. Defines the retrieve-then-generate architecture used by enterprise copilots	1. No notion of access control or document sensitivity 2. Privacy of the retrieval corpus is out of scope
2	2021	N. Carlini, F. Tramèr, E. Wallace et al.. Extracting Training Data from Large Language Models	1. Shows verbatim training-data extraction (incl. PII) from GPT-2 2. Establishes memorisation as a concrete privacy threat	1. Concerns training data, not retrieval context 2. Offers no deployable runtime defence
3	2023	N. Lukas, A. Salem, R. Sim et al.. Analyzing Leakage of Personally Identifiable Information in Language Models	1. Measures PII extraction, reconstruction and inference from fine-tuned LMs 2. Shows scrubbing and DP reduce but do not remove leakage	1. Fine-tuning setting; RAG context not studied 2. Western PII types; no Indian identifiers
4	2025	H. Wu, Y. Cao. Membership Inference Attacks on Large-Scale Models: A Survey	1. First survey of MIA across LLM/LMM pipeline stages including RAG 2. Calls for RAG-specific defences	1. Survey: no mitigation proposed 2. No unified mitigation taxonomy for RAG-stage MIA
5	2024	H. Mozaffari, V. J. Marathe. Semantic Membership Inference Attack against Large Language Models	1. Semantic-perturbation MIA (SMIA) outperforms prior attacks on Pythia/GPT-Neo 2. Uses semantic neighbours rather than token-level signals	1. Pre-training data only 2. Not evaluated on deployed enterprise assistants
6	2024	S. Zeng, J. Zhang, P. He et al.. The Good and The Bad: Exploring Privacy Issues in Retrieval-Augmented Generation (RAG)	1. Shows the retrieval database of a RAG system leaks under targeted prompts 2. Finds RAG can reduce leakage of the model's own training data	1. Defences explored are generic (summarisation, re-ranking) 2. No role, permission or purpose model
7	2024	Z. Qi, H. Zhang, E. Xing et al.. Follow My Instruction and Spill the Beans: Scalable Data Extraction from Retrieval-Augmented Generation Systems	1. Instruction-following prompts extract retrieved datastore content verbatim 2. Shows extraction scales with model capability	1. Attack-side paper 2. Assumes no screening layer in front of the model
8	2025	J. Liu, J. Zhang, S. Wang. Exposing Privacy Risks in Graph Retrieval-Augmented Generation	1. Graph RAG leaks structured entity/relationship data — a new surface vs plain RAG 2. Explores preliminary defences	1. No robust defence 2. Does not address role/permission-based access control
9	2026	X. Lyu, J. He, N. Wang et al.. ALDEN: Boosting Private Data Extraction from Retrieval-Augmented Generation Systems via Active Learning and Distribution Estimation	1. Active learning + distribution estimation beats prior RAG extraction attacks 2. Raises the extraction rate per query budget	1. Attack-side paper 2. Assumes no content-filtering middleware

10	2025	T. Zhang, Y. Jiang, R. Gong et al.. DEAL: High-Efficacy Privacy Attack on Retrieval-Augmented Generation Systems via LLM Optimizer	1. LLM-optimiser-crafted suffixes extract retrieved documents and PII 2. Reports near-total PII extraction on undefended RAG (as reported)	1. No defence proposed 2. Motivates — but does not provide — a screening layer
11	2025	H. Wang, X. Xu, B. Huang et al.. Privacy-Aware Decoding: Mitigating Privacy Leakage of Large Language Models in Retrieval-Augmented Generation	1. Calibrated noise on logits at decoding time reduces leakage of retrieved content 2. Studies the leakage–utility trade-off	1. Inference-time only; the LLM still receives the private context 2. No prompt-side or access-control defence
12	2026	Y. Zhang, J. Wu, R. Li, T. Zhang. Privacy protection in RAG: A novel method and evaluation framework	1. Shows coarse document-level redaction needlessly removes context 2. LLM-as-judge leakage metric and a two-stage retriever	1. Not role-aware 2. Does not model organisational permissions or purpose
13	2023	K. Greshake, S. Abdelnabi, S. Mishra et al.. Not what you've signed up for: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection	1. Introduces indirect prompt injection via retrieved content 2. Demonstrates data theft and manipulation in real LLM-integrated apps	1. Mostly attack demonstrations 2. Defences discussed qualitatively
14	2024	Y. Liu, Y. Jia, R. Geng et al.. Formalizing and Benchmarking Prompt Injection Attacks and Defenses	1. Formal framework unifying prompt-injection attacks 2. Systematic benchmark of attacks and defences	1. Task-level benchmark, not enterprise RAG 2. Privacy and access control out of scope
15	2026	T. Geng, Z. Xu, Y. Qu, W. E. Wong. Prompt Injection Attacks on Large Language Models: A Survey of Attack Methods, Root Causes, and Defense Strategies	1. Taxonomy of injection via the retrieval pathway; catalogues incidents 2. Surveys structural defences (StruQ, FATH)	1. Defences not evaluated together as one deployable pipeline 2. No privacy-regulation mapping
16	2025	OWASP Gen AI Security Project. LLM01:2025 Prompt Injection (OWASP Top 10 for LLM Applications)	1. Industry-standard taxonomy incl. RAG document poisoning 2. Mitigation guidance (segregate external content, filter I/O)	1. Guidance only 2. No reference implementation or measurements
17	2024	S. Chen, J. Piet, C. Sitawarin, D. Wagner. StruQ: Defending Against Prompt Injection with Structured Queries	1. Separates instructions from data with a structured query format 2. Fine-tunes the model to ignore instructions in the data channel	1. Requires model fine-tuning 2. Not available for hosted API models
18	2024	K. Hines, G. Lopez, M. Hall et al.. Defending Against Indirect Prompt Injection Attacks With Spotlighting	1. Marks untrusted input via delimiting, datamarking and encoding 2. Prompt-only defence usable with hosted models	1. Reduces but does not eliminate attack success 2. No screening, access control or audit
19	2023	H. Inan, K. Upasani, J. Chi et al.. Llama Guard: LLM-based Input-Output Safeguard for Human-AI Conversations	1. LLM-based classifier for unsafe inputs/outputs with a policy taxonomy 2. Shows an LLM can act as an adaptable safety judge	1. Targets content safety, not PII or permissions 2. Not integrated with retrieval or audit
20	2023	L. Zheng, W.-L. Chiang, Y. Sheng et al.. Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena	1. Validates strong LLMs as judges agreeing well with humans 2. Documents judge biases (position, verbosity)	1. Evaluates answer quality, not security classification 2. Judge errors remain
21	2026	K. Chu et al.. A Systematic Survey of Security Threats and Defenses in LLM-Based AI Agents: A Layered Attack Surface Framework	1. Formalises indirect injection across agent layers 2. Surveys sandboxing and trusted/untrusted separation	1. Focus on tool-using agents, not read-only copilots 2. No privacy-law mapping
22	2023	J. X. Morris, V. Kuleshov, V. Shmatikov, A. M. Rush. Text Embeddings Reveal (Almost) As Much As Text	1. Vec2Text iteratively inverts embeddings back to text 2. Recovers most of short inputs from their embeddings	1. Noise-based defences cost retrieval utility 2. Assumes access to the embedding vectors
23	2025	D. Seputis, Y. Li, K. Langerak et al.. Rethinking the Privacy of Text Embeddings: A Reproducibility Study of 'Text Embeddings Reveal (Almost) As Much As Text'	1. Reproduces Vec2Text inversion results 2. Examines conditions under which inversion succeeds	1. Defence utility loss not quantified for retrieval 2. Not tested inside an access-controlled pipeline
24	2020	C. Song, A. Raghunathan. Information Leakage in Embedding Models	1. Shows embeddings leak inputs via inversion and attribute inference 2. Studies membership inference on embedding models	1. Pre-RAG setting 2. Defences (adversarial training, noise) cost utility
25	2026	Y.-C. Tsai, H. Hsiao, K.-Y. Chen et al.. Concept-Aware Privacy Mechanisms for Defending Embedding Inversion Attacks (SPARSE)	1. Shows uniform-noise DP defences over-protect 2. Adds noise only on privacy-sensitive embedding dimensions	1. Not tested inside a live RAG pipeline 2. Leaves the raw text in the index
26	2026	P. Jha. PIIBench: A Unified Multi-Source Benchmark Corpus for Personally Identifiable Information Detection	1. Unified multi-source PII benchmark 2. Shows eight published detectors score low span-F1 on a unified taxonomy	1. Benchmark, not a detector 2. Confirms no detector generalises across enterprise PII types
27	2025	K. Mishra, H. Pagare, K. Sharma. A hybrid rule-based NLP and machine learning approach for PII detection and	1. Regex + custom NER anonymisation pipeline 2. Reports high precision/recall on	1. Finance-specific 2. Not validated on HR/ticket/email mixes or Indian identifiers

		anonymization in financial documents	financial documents	
28	2024	N. Mireshghallah, H. Kim, X. Zhou et al.. Can LLMs Keep a Secret? Testing Privacy Implications of Language Models via Contextual Integrity Theory	1. Benchmark (ConfAIde) showing LLMs reveal information in inappropriate contexts 2. Frames LLM privacy as contextual integrity, not just secrecy	1. Diagnoses the problem; no enforcement layer 2. Not tied to organisational access policy
29	2008	J.-W. Byun, N. Li. Purpose based access control for privacy protection in relational database systems	1. Defines purpose-based access control: access granted only for compatible purposes 2. Purpose hierarchies and enforcement in databases	1. Relational databases, not LLM retrieval 2. No notion of generated answers mixing sources
30	1996	R. S. Sandhu, E. J. Coyne, H. L. Feinstein, C. E. Youman. Role-based access control models	1. Foundational RBAC model family 2. Basis of the permissions enterprise copilots inherit	1. Static roles; no purpose 2. Document-level, blind to cross-document synthesis
31	2011	M. Deng, K. Wuyts, R. Scandariato, B. Preneel, W. Joosen. A privacy threat analysis framework: supporting the elicitation and fulfillment of privacy requirements	1. LINDDUN privacy threat-modelling framework 2. Maps privacy threats to requirements and controls	1. Pre-LLM; no AI-specific threats 2. Methodology, not an implementation
32	1999	B. Schneier, J. Kelsey. Secure audit logs to support computer forensics	1. Hash-chained, forward-secure audit logs 2. Tamper detection for forensic records	1. Pre-LLM 2. Detects tampering after the fact; does not prevent it

Gaps identified

- **G1 — No role- or purpose-awareness in RAG defences.** Decoding-time and retriever-side defences [11, 12] act on content, not on who is asking or why; the private context still reaches the model.
- **G2 — Attacks assume no screening layer.** Extraction attacks [7, 9, 10] are evaluated against undefended pipelines; the effect of a middleware in front of the model is unmeasured.
- **G3 — Injection defences are evaluated in isolation.** Delimiting [18], structured queries [17] and LLM guards [19] are not combined with access control, redaction and audit in one pipeline [15].
- **G4 — PII detection is not India-ready.** Detectors generalise poorly [26], domain pipelines are finance-only [27], and Presidio ships its Aadhaar/PAN recognizers disabled with none for IFSC, UPI or ₹ salaries.
- **G5 — No evaluation against DPDP.** Existing work is GDPR- or CCPA-oriented; no deployable defence has been mapped clause by clause to the DPDP Act 2023 and Rules 2025 with measured evidence.

Proposed method

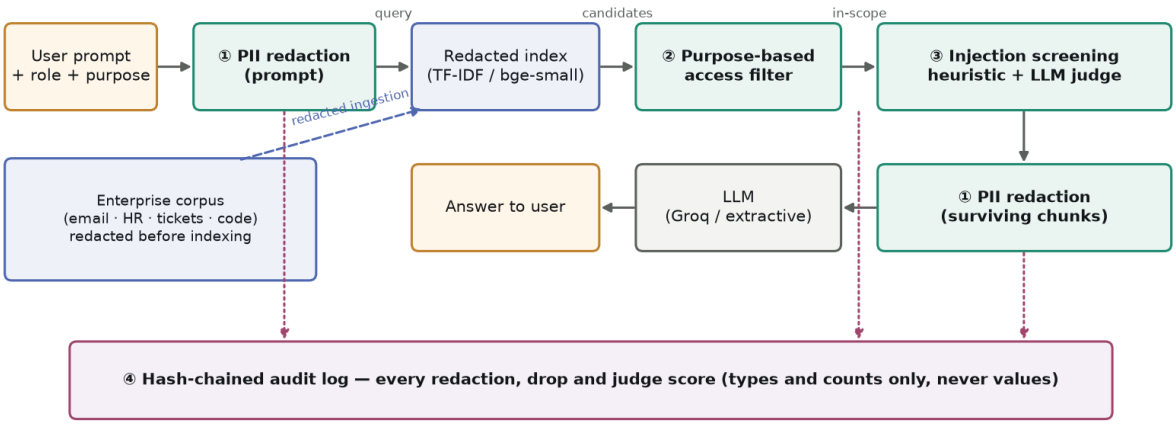


Figure 1. Copilot Privacy Guard: four controls plus a privacy-preserving index, every decision audited.

The middleware intercepts every prompt and every retrieved document before either reaches the LLM. All variants studied here are configurations of one pipeline (ConfigurableRAG) that share the retriever and the LLM, so only the defence differs.

- ① **PII detection and redaction.** A registry of India-first recognizers — Aadhaar with Verhoeff checksum, PAN, Indian mobile, IFSC, UPI VPA, card numbers with Luhn, dates of birth, rupee salaries, e-mail — plus spaCy NER and pattern rules for person names. Values become typed placeholders (<AADHAAR_1>). It runs on the prompt (so the retriever never sees raw PII), on documents before indexing, and on surviving chunks.
- **Privacy-preserving index.** The vector index (TF-IDF, or bge-small dense embeddings) is built from redacted documents, so an embedding-inversion attack has no raw identifiers to recover — the exposure point Review 2 marked as cross-silo ingestion.
- ② **Purpose-based access filter.** A chunk is released only if the user's clearance meets its sensitivity, its department matches (or it is public, or the user holds a cross-department role such as CISO/DPO) and the declared purpose of the query is one of the document's permitted purposes — DPDP purpose limitation as a runtime rule.
- ③ **Injection screening.** A weighted pattern bank with zero-width, HTML-comment and base64 checks, OR-combined with an LLM-as-judge (gpt-oss-120b, JSON verdict, cached). Flagged chunks are dropped; the rest are wrapped in <untrusted_document> delimiters.
- ④ **Hash-chained audit log.** Each decision is appended with SHA-256(previous hash ‖ entry); verification reports the first broken link. Entries store entity types and counts, user and purpose — never PII values.

Headline result (Table 2): on 36 queries the guard sends no raw PII to the LLM provider, releases no out-of-purpose chunk, stores no raw PII in its index and lets no poisoned chunk reach the model, at a utility cost of 34.9% ROUGE-L retention.

Table 2. Headline comparison (undefended vs ours).

Metric	Vanilla RAG	Copilot Privacy Guard
PII sent to LLM provider (context exposure)	100.0%	0.0%
PII in final answer (LLM answers)	13.1%	0.0%
Over-sharing retrieval rate	50.9%	0.0%
Raw PII stored in vector index	100.0%	0.0%
Poisoned chunks reaching the LLM	100.0%	0.0%
Injection success (canary obeyed by LLM)	0.0%	0.0%
Answer-quality retention (ROUGE-L / cosine)	100% / 100%	34.9% / 47.8%
Added latency per query (median)	0 ms	+97 ms

Experimental Analysis (with comparison to other research works)

Setup

Corpus: 80 synthetic Indian-enterprise documents (25 e-mails, 20 HR records, 20 tickets, 15 code/config files) generated with a fixed seed, tagged with department, sensitivity (0–3) and permitted purposes, with 369 ground-truth PII spans and four documents poisoned with canary-tagged injection payloads. Personas: HR manager, engineer, finance analyst, intern and CISO. Queries: 36 — 8 unauthorised probes, 8 authorised sensitive requests, 12 utility questions and 8 injection queries issued by a persona authorised to read the

poisoned document, so access control cannot trivially block them. LLMs (Groq): answers qwen/qwen3.8-27b, judge openai/gpt-oss-120b, comparator meta-llama/llama-prompt-guard-2-86m; all 407 responses are cached for exact reproducibility. Deterministic metrics come from an extractive answerer; LLM-dependent metrics (injection success, answer quality, answer leakage) from 8 injection and 12 utility queries answered by the LLM (0 fallbacks).

Comparative study against defence families

Each row below is a simplified analogue of a defence family from the literature, run on the same corpus, queries, retriever and LLM — not a reproduction of the cited paper.

Configuration (analogue of)	PII to LLM	Answer PII (LLM)	Over-sharing	Injection exposure	Injection success	ROUGE-L	Index PII	Latency
Vanilla RAG — Lewis et al. (2020) RAG; the undefended target of DEAL, ALDEN and Qi et al.	100.0%	13.1%	50.9%	100.0%	0.0%	100.0%	100.0%	+0 ms
Inherited RBAC (Copilot-style) — Role-based access control (Sandhu et al., 1996) as inherited by M365 Copilot	49.2%	9.2%	0.6%	59.4%	12.5%	69.2%	100.0%	-0 ms
Redaction-only DLP — Presidio-style / hybrid rule+NER PII redaction pipelines	0.0%	0.0%	50.9%	100.0%	12.5%	50.1%	100.0%	+40 ms
Output-side filtering — Output guardrails; the generation-side goal of Privacy-Aware Decoding (simplified)	100.0%	3.5%	50.9%	100.0%	0.0%	87.6%	100.0%	+8 ms
Delimiting only — Spotlighting (Hines et al., 2024) / StruQ-style separation without fine-tuning	100.0%	15.9%	50.9%	100.0%	0.0%	75.3%	100.0%	-0 ms
Heuristic screening only — Pattern-based injection filters catalogued in prompt-injection surveys	86.0%	13.6%	53.8%	0.0%	0.0%	70.9%	100.0%	-0 ms
Copilot Privacy Guard (ours) — this work: the four Fig. 2 controls + privacy-preserving index	**0.0%**	**0.0%**	**0.0%**	**0.0%**	**0.0%**	**34.9%**	**0.0%**	**+97 ms**

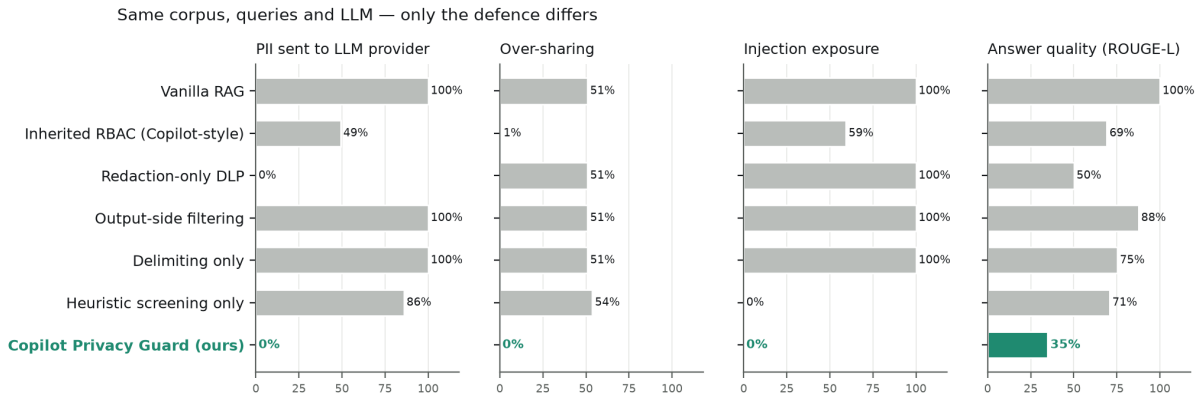


Figure 2. Same corpus, queries and LLM — only the defence differs (ours highlighted).

Inherited RBAC — how Copilot works — removes most clearance and department violations but still sends 49.2% of retrieved PII to the provider and lets 59.4% of poisoned chunks through. Redaction-only DLP removes PII from the context but leaves over-sharing at 50.9%: confidential non-personal content still crosses departments. Output-side filtering scrubs the answer yet sends 100% of PII to the provider — under DPDP §8(1) the fiduciary remains responsible for that processor exposure. Delimiting alone blocks nothing; heuristic screening removes seeded payloads but none of the privacy exposure. Only the combined guard drives all four exposure metrics to zero.

Injection success. The answer model resisted most seeded canary instructions on its own (vanilla: 0% of 8 attacked queries; worst case 12.5%). Model-level resistance is not a control the deployer owns, which is why the guard's design target is exposure: no poisoned chunk reaches the model at all.

Ablation

Configuration	PII to LLM	Over-sharing	Index PII	Injection exposure	ROUGE-L	Latency
Copilot Privacy Guard (ours)	0.0%	0.0%	0.0%	0.0%	34.9%	+97 ms
ours − LLM judge	0.0%	0.0%	0.0%	0.0%	34.9%	+98 ms
ours − access filter	0.0%	55.0%	0.0%	0.0%	43.8%	+121 ms
ours − PII redaction	48.8%	0.0%	100.0%	0.0%	49.7%	+58 ms
ours − redacted index	0.0%	0.0%	100.0%	0.0%	36.5%	+98 ms
ours on dense retrieval	0.0%	0.0%	0.0%	0.0%	34.4%	+130 ms

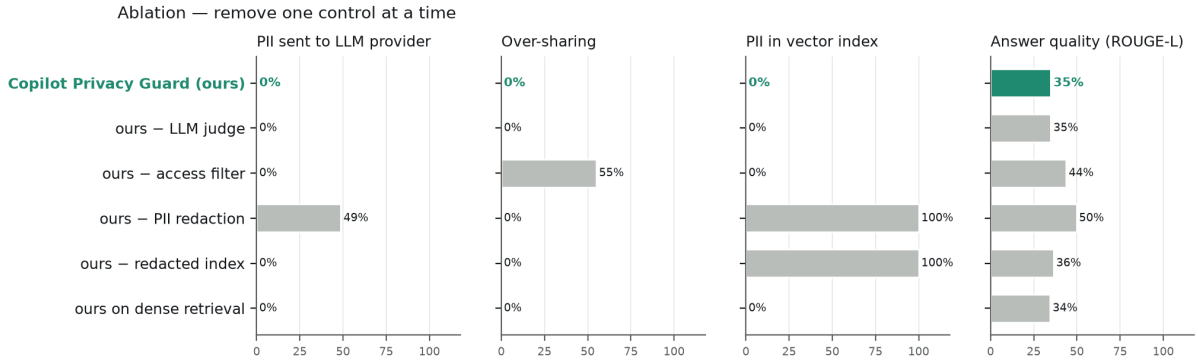


Figure 3. Removing one control at a time: each control owns one exposure.

Each control owns a distinct exposure: without the access filter over-sharing returns to 55.0%; without redaction 48.8% of PII reaches the provider; without the redacted index the index again holds 100% of raw PII. Removing the judge leaves these metrics unchanged on the corpus — its value shows on the harder payloads of the benchmark below — while cutting latency to +98 ms. Dense retrieval reproduces the privacy results.

Privacy–utility trade-off

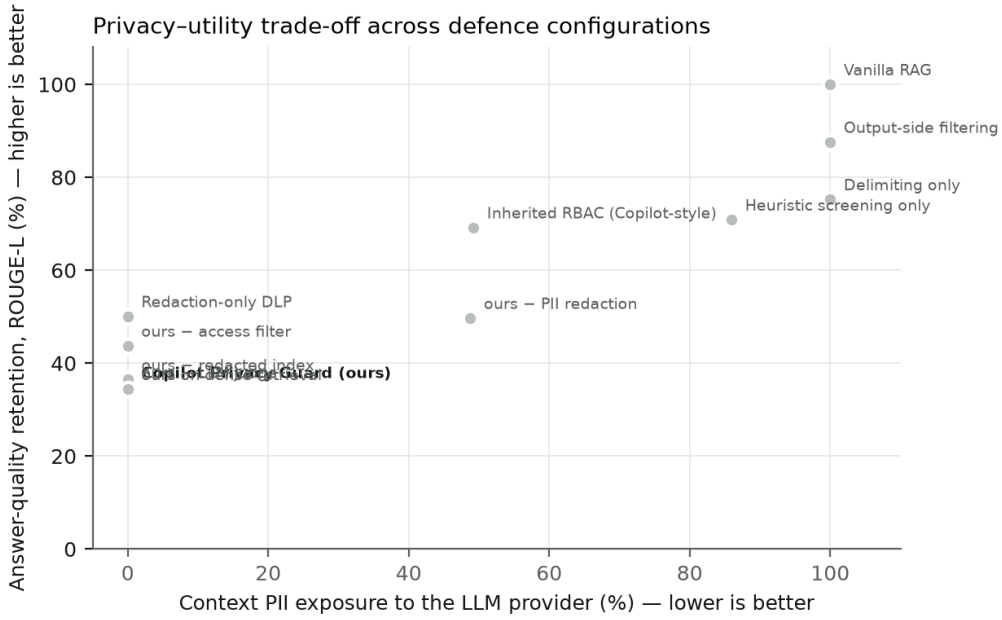


Figure 4. Context PII exposure vs answer-quality retention for every configuration.

The guard sits at zero exposure but the lowest answer-quality retention (34.9%). Utility questions often ask for names or contact details ('who should I contact…') that the guard deliberately replaces with placeholders, and the judge's OR-combination with the heuristic drops some benign chunks. The assurance check A12 (≥ 50% retention) therefore fails, and we report it as such.

PII detection: comparison with Microsoft Presidio

Entity type	Ours — held-out	Presidio (as shipped) — held-out	Presidio + India — held-out	Ours — corpus	Presidio (as shipped) — corpus	Presidio + India — corpus
AADHAAR	100%	0%	100%	100%	0%	100%
PAN	67%	0%	100%	100%	0%	100%
IN_MOBILE	80%	100%	100%	100%	100%	100%
IFSC	100%	0%	0%	95%	0%	0%
UPI_VPA	100%	0%	0%	90%	0%	0%
EMAIL	100%	100%	100%	100%	100%	100%
CREDIT_CARD	100%	100%	100%	100%	100%	100%
DOB	67%	100%	100%	95%	100%	100%
SALARY_INR	75%	0%	0%	100%	0%	0%
PERSON	88%	88%	88%	100%	67%	67%
PRECISION	93.8%	54.3%	58.1%	92.9%	65.0%	53.4%
RECALL	85.7%	54.3%	71.4%	98.9%	61.8%	75.6%
F1	89.5%	54.3%	64.1%	95.8%	63.3%	62.6%

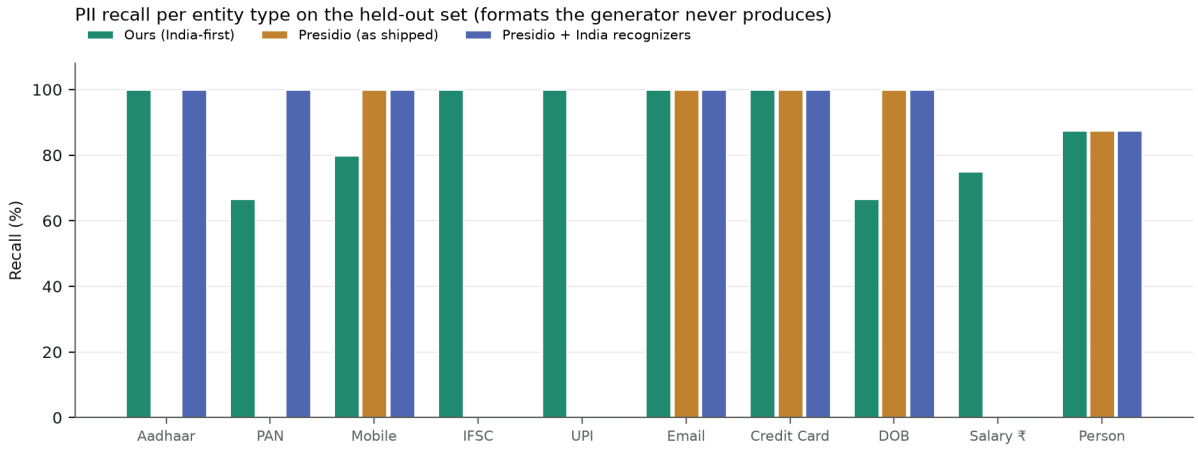


Figure 5. Per-type recall on the held-out set.

On the held-out set — sentences written in formats the generator never produces — our detector reaches F1 89.5% against 54.3% for Presidio as shipped and 64.1% with its India recognizers enabled. Presidio has no recognizer for IFSC, UPI or rupee salaries, and its Aadhaar/PAN recognizers are disabled by default. Presidio is better on spaced mobile numbers, written-out dates and lower-case PAN, which are genuine gaps in our patterns. Compared with the hybrid finance pipeline [27] our numbers are not directly comparable (different documents and taxonomy); PIIBench [26] warns that detectors generalise poorly, so the corpus figures (F1 95.8%) are an upper bound.

Injection detection: heuristic vs LLM judge vs Prompt Guard 2

Payload family	Heuristic	LLM judge	Combined (ours)	Prompt Guard 2
Direct	50%	100%	100%	75%
Roleplay	50%	100%	100%	50%
Exfiltration	25%	100%	100%	0%
Obfuscated	75%	100%	100%	25%
Paraphrased	0%	100%	100%	50%
Hindi	0%	100%	100%	0%
Detection (all 24)	33%	100%	100%	33%
FPR clean docs	0%	0%	0%	0%
FPR hard negatives	62%	0%	62%	12%

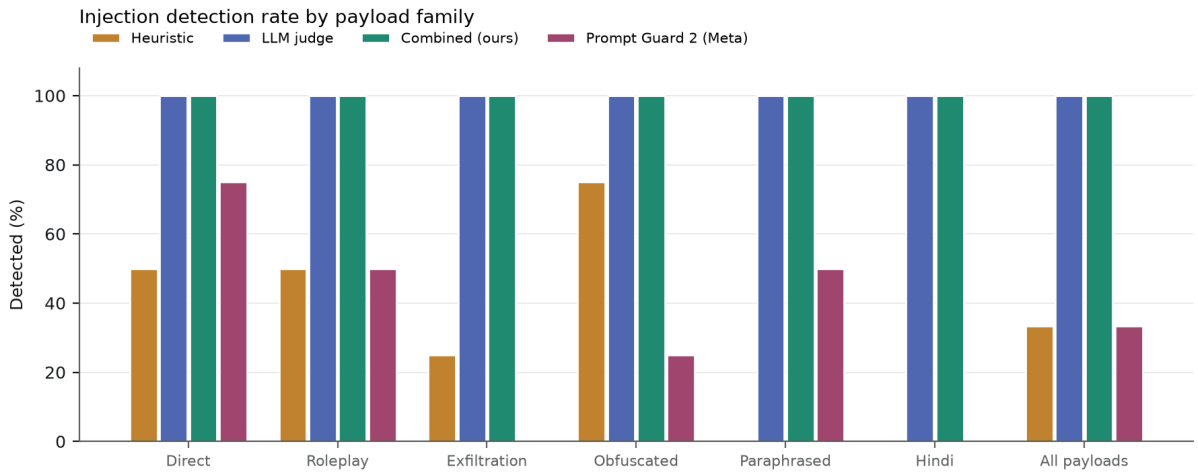


Figure 6. Detection rate by payload family.

The heuristic catches explicit and encoded payloads but none of the paraphrased or Hindi/Hinglish ones and falsely flags 62% of hard negatives (security reminders, release notes). The LLM judge detects all 24 payloads with no false positives. Meta's Prompt Guard 2, a dedicated classifier, detects 33% — it is strong on explicit overrides but misses exfiltration and Hindi payloads. Because the guard OR-combines heuristic and judge, it inherits the heuristic's false positives; making the judge the sole decision-maker is our first future-work item.

Replay of documented incidents

Incident	Exposure point	Injection screening	PII redaction	Access filter	Audit	Residual gap
EchoLeak, M365 Copilot (2025)	retrieval → inference	Partially	Partially	No	Yes	output egress allow-list
Slack AI injection (2024)	cross-zone retrieval	Yes (likely)	Partially	Partially	Yes	secret recognizers
Samsung → ChatGPT (2023)	prompt → external processor	No	Partially	No	Yes	non-personal confidential data

Compliance, DPIA and assurance checklist

Framework	Clauses mapped (each verified against the source text)
DPDP Act 2023	§4, §6(1), §7(i), §8(1), §8(5), §8(6), §10(2)(c)
DPDP Rules 2025	Rule 6, Rule 7, Rule 13
GDPR	Art. 5(1)(b), Art. 5(1)(c), Art. 5(1)(f), Art. 5(2), Art. 25, Art. 30, Art. 32, Art. 35
EU AI Act	Art. 12, Art. 15, Annex III(4)
OWASP LLM Top 10 (2025)	LLM01, LLM02, LLM08

ID	Threat	Inherent L×I	Controls	Residual L×I
R1	Permission over-sharing	16 (High)	access	4 (Low)
R2	Prompt and context leakage (incl. to the LLM provider)	20 (Critical)	pii, index	6 (Medium)
R3	Indirect prompt injection	16 (High)	injection	8 (Medium)
R4	Embedding / index inversion	12 (High)	index	4 (Low)
R5	Fine-tuning memorisation	4 (Low)	—	4 (Low)
R6	Sensitive-attribute inference by aggregation	12 (High)	access, pii	6 (Medium)
R7	Audit-trail tampering	8 (Medium)	audit	3 (Low)

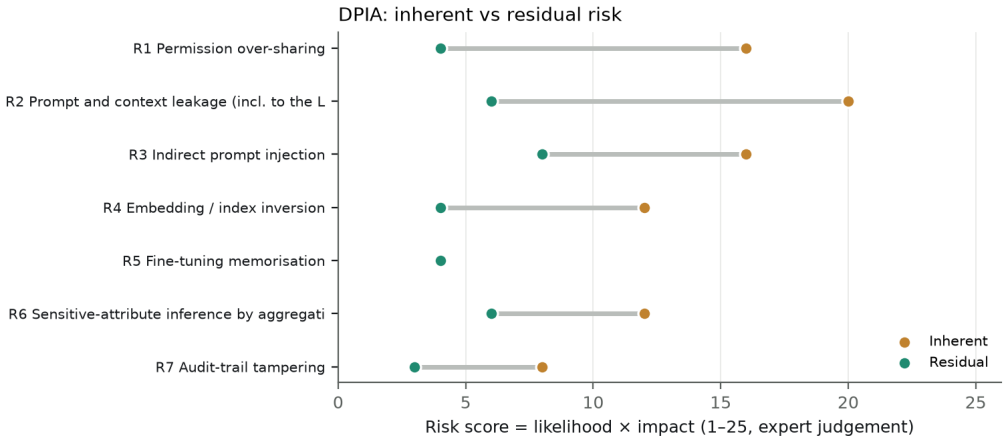


Figure 7. DPIA risk register: inherent vs residual (likelihood × impact, expert judgement).

12 of 13 executable assurance checks pass against the running system and its results; failing: A12 (Non-sensitive answers keep at least 50% ROUGE-L overlap with the undefended system.).

Comparison with results reported in the literature

The rows below place our measurements beside numbers reported by other works. Settings, data and models differ, so this is context, not a head-to-head comparison.

Work	Their setting	Reported result	Our closest measurement	Comparable?
DEAL [10]	Optimiser attack on undefended RAG	near-total PII extraction (as reported)	Vanilla RAG sends 100% of PII to the LLM; guard 0%	No — different attack
PAD [11]	Decoding-time noise	leakage–utility trade-off	Guard: 0% PII in context, 34.9% ROUGE-L	No — PAD leaves PII in the context
Spotlighting [18]	Prompt delimiting	reduced attack success	'Delimiting only': injection exposure 100%, success 0%	Analogue on our data
Vec2Text [22]	Embedding inversion	recovers most of short inputs	Index PII exposure 100% → 0%	Partially — we remove what inversion could recover
Hybrid PII [27]	Financial documents	high precision/recall (as reported)	Held-out F1 89.5%	No — different documents
PIIBench [26]	Unified multi-source taxonomy	low span-F1 for 8 detectors	Presidio held-out F1 54.3%	No — smaller, narrower set

Threats to validity

- Synthetic corpus: written by the authors; the held-out PII set reduces but does not remove this bias.
- Two detector fixes were made after the first comparison run exposed residual leaks (first names after e-mail sign-offs; name patterns crossing line breaks into HR record titles). The fixes are general, the held-out set contains neither pattern, and both are disclosed here.
- Small sets: 36 queries and 24 payloads; injection success rests on 8 attacked queries.
- Likelihood/impact scores in the DPIA are expert judgement; only residual scores are tied to measured evidence.
- Comparative configurations are simplified analogues, not reproductions of the cited systems.
- Latency is the median per-query delta with committed caches (robust to rate-limit back-off); an uncached judge call takes about 553 ms.
- Three of the four corpus payloads contain their canary verbatim, so a model that quoted rather than obeyed would count as an injection success; the exposure metric does not depend on this.

Future work

- Make the LLM judge the sole drop decision (heuristic for logging only) to remove the heuristic's false positives and recover utility.
- Re-identify placeholders in the final answer for users authorised to see them (a tokenisation vault), so the LLM never sees PII but HR still gets real values.
- Add recognizers for credentials/secrets, spaced mobile numbers, written-out dates and lakh/crore amounts; evaluate on PIIBench.
- Output egress controls (link and image allow-listing) — the residual gap in the EchoLeak and Slack AI replays.
- Integrate with an identity provider (Entra ID / Google Workspace) for live ACLs and a consent prompt for declared purpose.

- Evaluate on a real (consented, de-identified) enterprise corpus and against adaptive attacks.

Conclusion

Enterprise copilots turn latent over-sharing into an instant, conversational disclosure channel. A layered middleware — redaction before indexing and retrieval, purpose-based access control, injection screening with an LLM judge, and a tamper-evident audit trail — removed every measured exposure on our benchmark (0% PII to the provider, 0% over-sharing, 0% raw PII in the index, 0% poisoned chunks reaching the model), where every single-family defence left at least one exposure open. The price is utility and latency, which we quantify rather than hide. Mapping each control to DPDP, GDPR and EU AI Act clauses with measured evidence shows how such a guard can support compliance in Indian organisations ahead of the 2027 enforcement date.

References

1. P. Lewis, E. Perez, A. Piktus et al.. "Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks." *NeurIPS 2020 (arXiv:2005.11401)* (2020). https://arxiv.org/abs/2005.11401
2. N. Carlini, F. Tramèr, E. Wallace et al.. "Extracting Training Data from Large Language Models." *USENIX Security 2021 (arXiv:2012.07805)* (2021). https://arxiv.org/abs/2012.07805
3. N. Lukas, A. Salem, R. Sim et al.. "Analyzing Leakage of Personally Identifiable Information in Language Models." *IEEE S&P 2023 (arXiv:2302.00539)* (2023). https://arxiv.org/abs/2302.00539
4. H. Wu, Y. Cao. "Membership Inference Attacks on Large-Scale Models: A Survey." *arXiv:2503.19338* (2025). https://arxiv.org/abs/2503.19338
5. H. Mozaffari, V. J. Marathe. "Semantic Membership Inference Attack against Large Language Models." *arXiv:2406.10218* (2024). https://arxiv.org/abs/2406.10218
6. S. Zeng, J. Zhang, P. He et al.. "The Good and The Bad: Exploring Privacy Issues in Retrieval-Augmented Generation (RAG)." *Findings of ACL 2024 (arXiv:2402.16893)* (2024). https://arxiv.org/abs/2402.16893
7. Z. Qi, H. Zhang, E. Xing et al.. "Follow My Instruction and Spill the Beans: Scalable Data Extraction from Retrieval-Augmented Generation Systems." *arXiv:2402.17840* (2024). https://arxiv.org/abs/2402.17840
8. J. Liu, J. Zhang, S. Wang. "Exposing Privacy Risks in Graph Retrieval-Augmented Generation." *arXiv:2508.17222* (2025). https://arxiv.org/abs/2508.17222
9. X. Lyu, J. He, N. Wang et al.. "ALDEN: Boosting Private Data Extraction from Retrieval-Augmented Generation Systems via Active Learning and Distribution Estimation." *arXiv:2605.18762* (2026). https://arxiv.org/abs/2605.18762
10. T. Zhang, Y. Jiang, R. Gong et al.. "DEAL: High-Efficacy Privacy Attack on Retrieval-Augmented Generation Systems via LLM Optimizer." *OpenReview (sx8dtyZT41)* (2025). https://openreview.net/forum?id=sx8dtyZT41
11. H. Wang, X. Xu, B. Huang et al.. "Privacy-Aware Decoding: Mitigating Privacy Leakage of Large Language Models in Retrieval-Augmented Generation." *arXiv:2508.03098* (2025). https://arxiv.org/abs/2508.03098
12. Y. Zhang, J. Wu, R. Li, T. Zhang. "Privacy protection in RAG: A novel method and evaluation framework." *Information Processing & Management* (2026). https://doi.org/10.1016/j.ipm.2025.104505
13. K. Greshake, S. Abdelnabi, S. Mishra et al.. "Not what you've signed up for: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection." *AISec 2023 (arXiv:2302.12173)* (2023). https://arxiv.org/abs/2302.12173
14. Y. Liu, Y. Jia, R. Geng et al.. "Formalizing and Benchmarking Prompt Injection Attacks and Defenses." *USENIX Security 2024 (arXiv:2310.12815)* (2024). https://arxiv.org/abs/2310.12815
15. T. Geng, Z. Xu, Y. Qu, W. E. Wong. "Prompt Injection Attacks on Large Language Models: A Survey of Attack Methods, Root Causes, and Defense Strategies." *Computers, Materials & Continua* (2026). https://doi.org/10.32604/cmc.2025.074081

16. OWASP Gen AI Security Project. "LLM01:2025 Prompt Injection (OWASP Top 10 for LLM Applications)." *genai.owasp.org* (2025). https://genai.owasp.org/llmrisk/llm01-prompt-injection/
17. S. Chen, J. Piet, C. Sitawarin, D. Wagner. "StruQ: Defending Against Prompt Injection with Structured Queries." *USENIX Security 2025 (arXiv:2402.06363)* (2024). https://arxiv.org/abs/2402.06363
18. K. Hines, G. Lopez, M. Hall et al.. "Defending Against Indirect Prompt Injection Attacks With Spotlighting." *arXiv:2403.14720* (2024). https://arxiv.org/abs/2403.14720
19. H. Inan, K. Upasani, J. Chi et al.. "Llama Guard: LLM-based Input-Output Safeguard for Human-AI Conversations." *arXiv:2312.06674* (2023). https://arxiv.org/abs/2312.06674
20. L. Zheng, W.-L. Chiang, Y. Sheng et al.. "Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena." *NeurIPS 2023 (arXiv:2306.05685)* (2023). https://arxiv.org/abs/2306.05685
21. K. Chu et al.. "A Systematic Survey of Security Threats and Defenses in LLM-Based AI Agents: A Layered Attack Surface Framework." *arXiv:2604.23338* (2026). https://arxiv.org/abs/2604.23338
22. J. X. Morris, V. Kuleshov, V. Shmatikov, A. M. Rush. "Text Embeddings Reveal (Almost) As Much As Text." *EMNLP 2023 (arXiv:2310.06816)* (2023). https://arxiv.org/abs/2310.06816
23. D. Seputis, Y. Li, K. Langerak et al.. "Rethinking the Privacy of Text Embeddings: A Reproducibility Study of 'Text Embeddings Reveal (Almost) As Much As Text'." *arXiv:2507.07700* (2025). https://arxiv.org/abs/2507.07700
24. C. Song, A. Raghunathan. "Information Leakage in Embedding Models." *ACM CCS 2020* (2020). https://doi.org/10.1145/3372297.3417270
25. Y.-C. Tsai, H. Hsiao, K.-Y. Chen et al.. "Concept-Aware Privacy Mechanisms for Defending Embedding Inversion Attacks (SPARSE)." *arXiv:2602.07090* (2026). https://arxiv.org/abs/2602.07090
26. P. Jha. "PIIBench: A Unified Multi-Source Benchmark Corpus for Personally Identifiable Information Detection." *arXiv:2604.15776* (2026). https://arxiv.org/abs/2604.15776
27. K. Mishra, H. Pagare, K. Sharma. "A hybrid rule-based NLP and machine learning approach for PII detection and anonymization in financial documents." *Scientific Reports* (2025). https://doi.org/10.1038/s41598-025-04971-9
28. N. Mireshghallah, H. Kim, X. Zhou et al.. "Can LLMs Keep a Secret? Testing Privacy Implications of Language Models via Contextual Integrity Theory." *ICLR 2024 (arXiv:2310.17884)* (2024). https://arxiv.org/abs/2310.17884
29. J.-W. Byun, N. Li. "Purpose based access control for privacy protection in relational database systems." *The VLDB Journal 17(4)* (2008). https://doi.org/10.1007/s00778-006-0023-0
30. R. S. Sandhu, E. J. Coyne, H. L. Feinstein, C. E. Youman. "Role-based access control models." *IEEE Computer 29(2)* (1996). https://doi.org/10.1109/2.485845
31. M. Deng, K. Wuyts, R. Scandariato, B. Preneel, W. Joosen. "A privacy threat analysis framework: supporting the elicitation and fulfillment of privacy requirements." *Requirements Engineering 16(1)* (2011). https://doi.org/10.1007/s00766-010-0115-7
32. B. Schneier, J. Kelsey. "Secure audit logs to support computer forensics." *ACM TISSEC 2(2)* (1999). https://doi.org/10.1145/317087.317089

Statutes and standards: Digital Personal Data Protection Act, 2023; Digital Personal Data Protection Rules, 2025 (G.S.R. 846(E), 13 Nov 2025); Regulation (EU) 2016/679 (GDPR); Regulation (EU) 2024/1689 (AI Act); OWASP Top 10 for LLM Applications 2025. Clause-level sources: results/compliance.md.